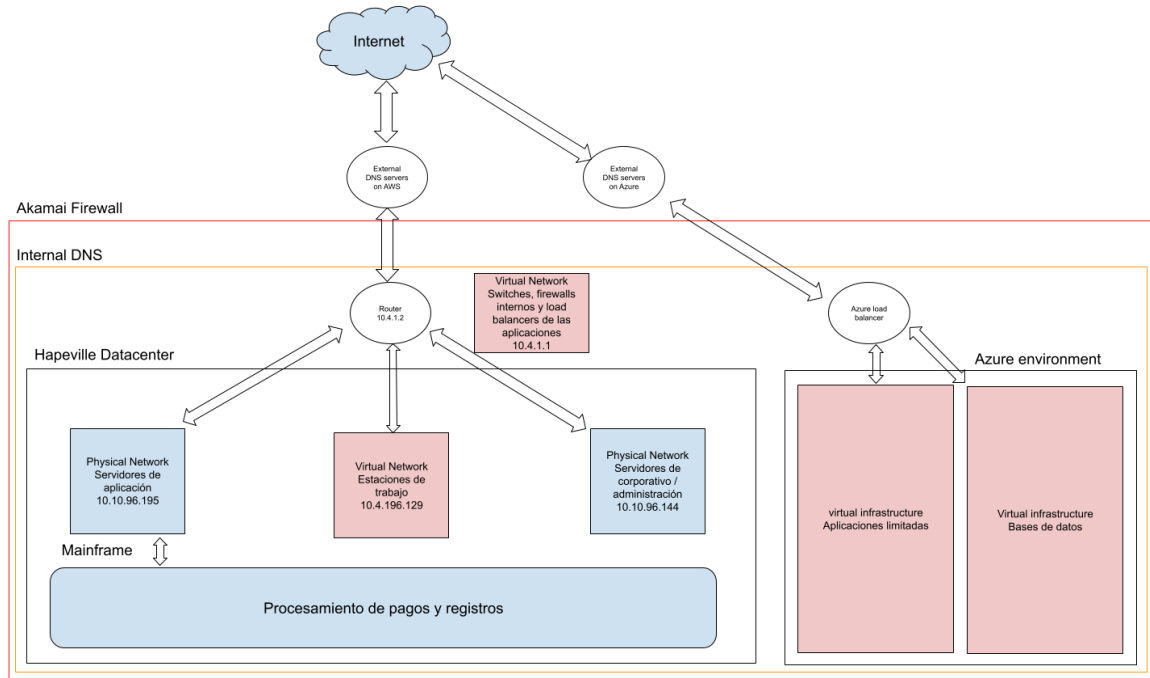


Análisis de seguridad de una arquitectura de red corporativa híbrida (on-premise + nube)

1.- Diagrama de la red:



La empresa es dueña de un centro de datos en Hapeville donde se encuentran todos los servidores corporativos y el mainframe donde se realizan pagos y transacciones.

Para asegurarse que las conexiones que entran sean seguras, tienen contratado el firewall de akamai para filtrar todas sus conexiones y además cada una de sus aplicaciones usan los firewalls de donde están montadas, también utilizan un sistema de doble DNS para mantener la información de sus servidores privada

También la empresa cuenta con un sistema de azure para hostear y manejar aplicaciones que no procesan pagos o transacciones monetarias

Segmento	Rango	Funcion	Gateway
External DNS		Conectar el internet con el firewall de Akamai	Internet
Akamai Firewall		Frontera entre External DNS e Internal DNS	External DNS
Internal DNS		Una vez validada la conexión, da la ip correcta para las aplicaciones	Akamai Firewall
VLAN de switches y load balancers	10.4.1.1/24	Balancear las cargas, dar internet a la oficina y mandar las solicitudes a las	Internal DNS

		aplicaciones correspondientes	
VLAN para estaciones de trabajo	10.4.196.129/24	Permitir realizar tareas en el mainframe	VLAN de Switches y load balancers
Red física para servidores corporativos	10.10.96.144/24	Mantiene los sistemas corporativos de funcionamiento interno	VLAN de Switches y load balancers
Red física para aplicación	10.10.96.195/24	Asegura el funcionamiento de las aplicaciones importantes de la empresa	VLAN de Switches y load balancers
Mainframe		Maneja las transacciones monetarias que ocurren en las aplicaciones	Red física para aplicación
Azure		Maneja aplicaciones que no utilizan transacciones monetarias	Akamai Firewall

2. Análisis de riesgos por capa y propuesta de mitigaciones

Capa	Ataque	superficie de ataque específica	Impacto	Mitigación
Enlace	VLAN hopping	Si un atacante obtiene acceso a una estación de trabajo, podría tratar de escapar de su VLAN para modificar la información que se encuentra en el mainframe	Alto	Mantener segmentación, seguridad en los puertos y forzar a los switches a desactivar DTP
Enlace	MAC spoofing	Un atacante que obtiene acceso podría hacerse pasar por otro dispositivo y ver el tráfico en el sistema	Medio	Mantener segmentación e implementar DHCP snooping
Transporte	Puertos expuestos	En caso que algún servidor de aplicación estuviera abierto, podría ser usado para realizar conexiones ilegítimas	Medio	Tener un firewall para cada aplicación y cerrar servicios innecesarios
Transporte	SYN Flooding	Si muchas solicitudes no se completan podría consumir muchos recursos y provocar	Alto	Tener un límite de conexiones y dedicar recursos a tener load balancers y protección para

		una denegación de servicio		DDoS
Red	IP Spoofing	Si un atacante pudiera falsificar su IP podría intentar obtener acceso a otras redes internas	Medio	Mantener segmentación e implementar firewalls entre aplicaciones
Red	ICMP redirect spoofing	Si un atacante pudiera modificar rutas podría obtener información clasificada	medio	Mantener segmentación e implementar firewalls entre aplicaciones

3. Mitigaciones

Muchas de las mitigaciones propuestas en la sección anterior han sido implementadas en el diseño final de la infraestructura, debido a la importancia de las operaciones que ocurren en el mainframe. La segmentación es aplicada agresivamente y todos los sistemas funcionan bajo la idea de deny by default y mínimo privilegio al punto de llegar a complicar que nuevas conexiones legítimas funcionen.

Incluso una vez el firewall de Akamai ha filtrado las conexiones, cada sistema de aplicación incluye otro firewall que también chequea la conexión, esto es para asegurar que la conexión sea legítima y debe de suceder, evitando que si algún atacante logró tener acceso a la red privada no pueda comunicarse con el mainframe, que es el punto más importante del sistema.

4. Riesgos residuales

Localización	Riesgo que se mantiene	Acción para prevenir
On-premises	Que un equipo legítimo y con credenciales válidas sea comprometido por algún atacante que ingrese a las instalaciones sin autorización	Mantener seguridad y restricción de acceso en el data center así como implementar políticas para no poder introducir dispositivos electrónicos
Nube	Que un miembro del equipo sea víctima de phishing y utilicen sus credenciales para obtener acceso ilegítimo a información confidencial	Mantener una cultura de seguridad y solo utilizar canales de comunicación oficiales para realizar
Interconexión	Incluso con todas las medidas para crear segmentación en el sistema, existe la probabilidad que la API que responde pueda ser manipulada para tratar de escribir en el mainframe	Programar un monitoreo entre los segmentos para detectar si hay cambios en el tráfico y poder detectar y rastrear las conexiones que ocurran en el sistema

5. ¿Cómo cambiaría el análisis si la VPN sitio-a-sitio se reemplaza por un enlace dedicado? Mencionar cambios en superficie de ataque, mitigaciones en capa de enlace/red, y costo/beneficio en seguridad.

Al tener un enlace dedicado se reduce la exposición de los gateways al internet permitiendo mayor privacidad para el sistema, esto claramente reduce la posible superficie del ataque pero los riesgos mencionados en las 2 capas seguirán teniendo el mismo posible impacto y por ende las mitigaciones al sistema se mantendrán igual. En la práctica y para un sistema así de importante el costo beneficio es completamente justificable ya que podríamos tener mayor control de nuestro sistema y tráfico.

6. Referencias:

1. P. Ferguson y D. Senie, «Network Ingress Filtering: Defeating Denial of Service Attacks which employ IP Source Address Spoofing», may 2000. doi: 10.17487/rfc2827.
2. L. Jiyuan, «What Is DHCP Snooping? hy Do We Need DHCP Snooping? - Huawei», *Huawei*, 4 de noviembre de 2024. <https://info.support.huawei.com/info-finder/encyclopedia/en/DHCP+Snooping.html>
3. Akamai, «Linode Cloud Firewalls», *Akamai Firewalls Documentation*, 2026. <https://techdocs.akamai.com/cloud-computing/docs/cloud-firewall>
4. Cloudflare, «SYN flood attack», *Cloudflare*, 2026. <https://www.cloudflare.com/learning/ddos/syn-flood-ddos-attack/>
5. IBM, *Reduce risk and improve security on IBM mainframes: Volume 1 architecture and platform security*, 1.^a ed., vol. 1. 2014. [En línea]. Disponible en: <https://www.redbooks.ibm.com/redbooks/pdfs/sg247803.pdf>
6. X. Feng, Q. Li, K. Sun, Y. Yang, y K. Xu, «Traffic Hijacking in Wi-Fi Networks via ICMP Redirects», *ACM Turing Award Celebration Conference - China (ACM TURC)*, pp. 141-142, jul. 2023, doi: 10.1145/3603165.3607441.
7. G. Sharadin, *What is VLAN Hopping | Risks, Attacks & Prevention | Imperva*. [En línea]. Disponible en: <https://www.imperva.com/learn/availability/vlan-hopping/>